

PROS-NC-PROS-NC-012

PROCEDIMIENTO GESTIÓN DE CRISIS POR INCIDENTES DE SEGURIDAD

Sistema de Gestión de Seguridad de la Información – Nivel Central

Versión Oficial Actual v01 – Agosto 2021

	Responsable	Fecha	Firma
Elaborado	Rodrigo Vidal / Unidad de Seguridad TIC	Agosto 2021	
Revisado	Ricardo Pardo / Andrés Muñoz Unidad Operaciones TIC	Agosto 2021	
Revisado	José Villa / Encargado Ciberseguridad	Agosto 2021	
Aprobado	Gino Paolo Peirano Alvarado Jefe Departamento Tecnologías de la Información y Comunicaciones	Agosto 2021	



CONTENIDO

1	PROPÓSITO	3
2	ALCANCE	3
3	TERMINOLOGÍA.....	4
4	DOCUMENTOS APLICABLES	4
5	ROLES Y RESPONSABILIDADES	4
6	PROCEDIMIENTO	4
6.1	GESTIÓN DE INCIDENTES CRITICOS	4
6.2	FLUJO GENERAL DEL PROCESO	5
6.3	COMITÉ DE CRISIS	5
6.4	PREPARACIÓN.....	9
6.4.1	Instalaciones y comunicación para la gestión de incidentes	9
6.4.2	Hardware y software para la gestión de incidentes	10
6.4.3	Recursos para el análisis	11
6.4.4	Software para mitigación	11
6.5	IDENTIFICACIÓN	11
6.6	CONTENCIÓN.....	11
6.7	PLAN DE COMUNICACIÓN.....	12
6.8	ERRADICACIÓN	13
6.9	RECUPERACIÓN	13
6.10	LECCIONES APRENDIDAS.....	13
8	DIFUSION	14
9	REVISION Y MEDICION	14
10	EXCEPCIONES AL CUMPLIMIENTO DEL PROCEDIMIENTO	14
11	CONTROL DE VERSIONES	14
12	ANEXO: CHECKLIST GESTIÓN DE INCIDENCIAS	15
13	ANEXO: Orientaciones sobre niveles y criterio de evaluación y clasificación de crisis.....	18

1 PROPÓSITO

Establecer las actividades necesarias en la Subsecretarías de Salud Pública y Redes Asistenciales, para el tratamiento de incidencias mayores que requieran de un Comité de Crisis para su gestión.

2 ALCANCE

Este procedimiento aborda la gestión de incidentes mayores y requieran la activación de Comités de Crisis, y que afecten a los activos de información del tipo: base de datos, documento, equipo, expediente, formulario, infraestructura física, persona, sistema de información, software, en cuanto a la;

- Confidencialidad: acceso no autorizado a la información,
- Integridad: Modificación no autorizada, destrucción o pérdida de información
- Disponibilidad: Inaccesibilidad a la información.

Este procedimiento es aplicable a todos los funcionarios¹ (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.), que presten servicios para las Subsecretarías de Salud Pública y de Redes Asistenciales y que tengan derechos de acceso a la información que puedan afectar los activos de información del Ministerio de Salud.

Este procedimiento abarca los siguientes controles definidos en la norma NCh-ISO 27001.Of2013:

Alcance de Dominios y Controles de Seguridad de la Información (Nch-ISO 27001:2013)		
Nombre del Dominio	ID Control ISO 27001	Nombre del Control
Organización de la seguridad de la información	A.06.01.03	Contacto con autoridades
	A.06.01.04	Contacto con grupos especiales de interés
Gestión de Incidentes	A.16.01.01	Responsabilidades y procedimientos
	A.16.01.02	Informe de eventos de seguridad de la información
	A.16.01.03	Informe de las debilidades de seguridad de la información
	A.16.01.04	Evaluación y decisión sobre los eventos de seguridad de la información
	A.16.01.05	Respuesta ante incidentes de seguridad de la información
	A.16.01.06	Aprendizaje de los incidentes de seguridad de la información
	A.16.01.07	Recolección de evidencia

¹ A lo largo del procedimiento cada vez que se mencione funcionario se refiere a: funcionarios (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.).



PROCEDIMIENTO GESTIÓN DE CRISIS POR INCIDENTES DE SEGURIDAD - PROS-NC-012

MINISTERIO DE SALUD

Versión: 01

Página 4 de 19

3 TERMINOLOGÍA

MINSAL: Ministerio de Salud.

SGSI: Sistema de Gestión de Seguridad de Información.

CSIRT: Equipo de Respuesta ante Emergencias Informáticas.

4 DOCUMENTOS APLICABLES

Documentos del Sistema de Gestión de Seguridad de la Información (SGSI) de MINSAL

Política Nacional de Ciberseguridad (PNCS)

El Marco Jurídico referido a los Sistemas de Seguridad de la Información (SSI), publicado en el portal del CSIRT del Ministerio del Interior:

- Decretos Supremos y Normas Internacionales de Seguridad de la Información y Ciberseguridad: <https://www.csirt.gob.cl/decretos/>
- Leyes relacionadas: <https://www.csirt.gob.cl/leyes/>

5 ROLES Y RESPONSABILIDADES

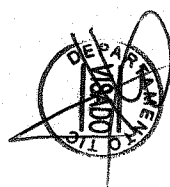
- Miembros comité de Crisis y sus Subrogantes:
 - Ver tabla del punto 6.1 con el detalle de las responsabilidades.
- Funcionarios
 - Informar cualquier evento o debilidad que pueda afectar la seguridad de la información.

6 PROCEDIMIENTO

6.1 GESTIÓN DE INCIDENTES CRITICOS

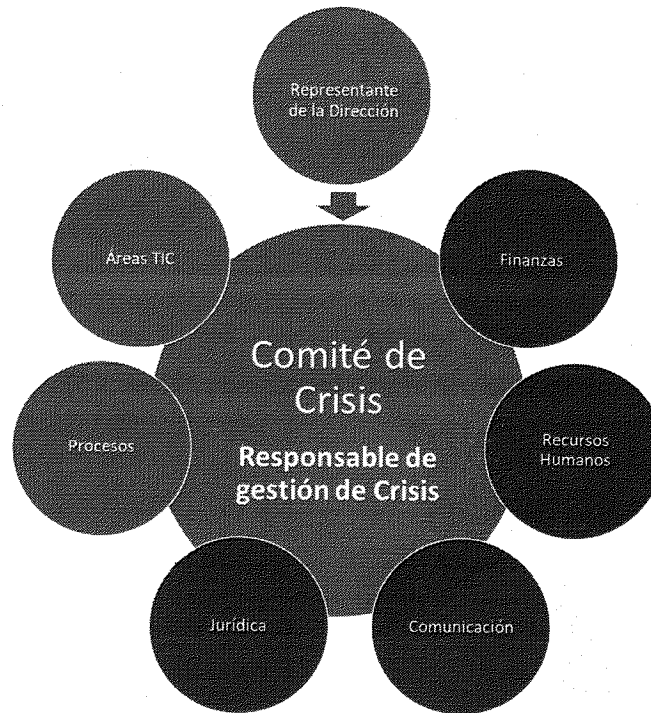
La Institución llevará adelante la respuesta a incidentes a través de sus instancias técnicas y se coordinará con el equipo de respuesta a Incidentes y el Comité de Crisis, en la medida que el impacto de los incidentes afecte a los activos vitales de la organización.

Los problemas relacionados a los incidentes de seguridad de la información dentro de la organización serán manejados por el Encargado de Seguridad de la Información y Ciberseguridad y/o quien asigne el Jefe Departamento Tecnologías de la Información y Comunicaciones, el que se apoyará en el personal equipo de respuesta a Incidentes y el Comité de Crisis, con atención al resguardo de los principios de la Política General y las leyes vigentes. A su vez, el Encargado de Seguridad de la información y Ciberseguridad mantendrá los contactos correspondientes con las autoridades, grupos de interés externos o foros que manejen los problemas relacionados con los incidentes de seguridad de la información.



su
los

distintos responsables en cada caso, desde lo operativo para la contención y resolución del incidente, hasta la coordinación y comunicación que velará por la imagen de la institución, estableciendo la política de información, con los comunicados más adecuados y canales oportunos.

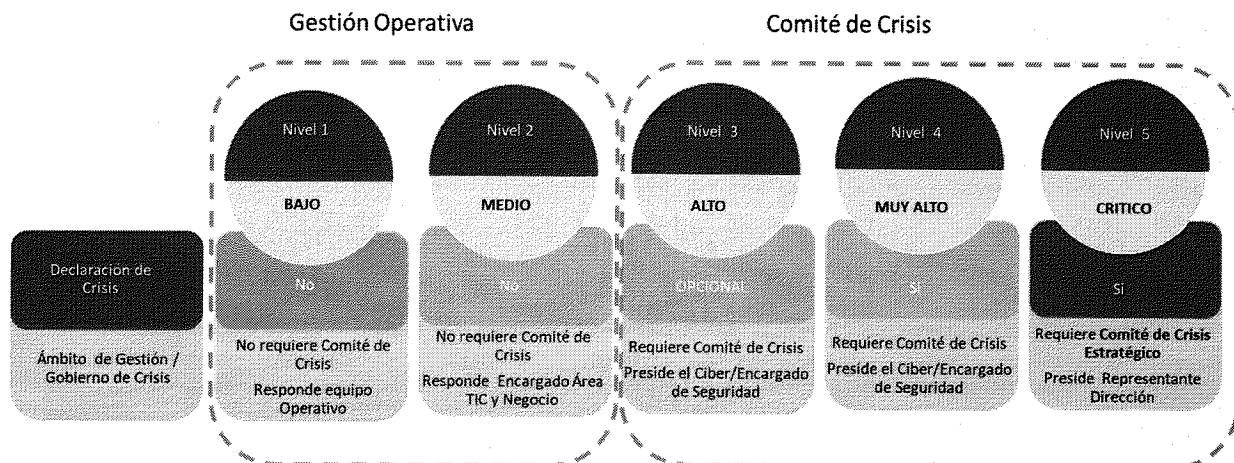


A continuación, se presenta un cuadro resumen de los actores del Comité de Crisis y sus responsabilidades:

Representante	Responsabilidades
CEO/Representante Dirección General /Presidente	▪ Inicia la gestión de crisis y preside el comité de crisis. ▪ Delega responsabilidades. ▪ Se mantiene permanentemente informado. ▪ Actúa como portavoz si las circunstancias lo exigen.
Encargado de Ciber/Seguridad de la Información	▪ Es el primero en conocer el incidente y debe determinar nivel de criticidad (Impacto y Urgencia), si es preciso trasladarlo o no al comité de Crisis. ▪ Notifica al CSIRT de referencia. ▪ Determina cuáles son las primeras acciones operativas para su contención.
TIC	▪ Gestiona la continuidad de los servicios, utilizando según sea el caso, los respaldos o sitios de contingencia para los servicios críticos.

Representante	Responsabilidades
	- Revisa el entorno común de todas las aplicaciones (comunicaciones, firewall, DNS, etc.), así como los específicos de cada aplicación. - Gestionará de forma rápida servidores virtuales en caso de ser necesario. - Activar Política de copias de seguridad. - Activar infraestructura de contingencia.
PMO o Encargado del Proyecto	Coordinar con los proveedores todas las acciones de contención, erradicación y cierre de los incidentes.
Jurídica	- Determina las responsabilidades legales directas provocadas por el incidente. - Da seguimiento a las acciones a seguir de acuerdo a la leyes y normas aplicables. - Orienta sobre todos los asuntos legales.
Comunicaciones	- Integra el Comité de Crisis y adopta el Manual de comunicaciones de crisis previamente elaborado. - Decide cuáles son los mensajes clave, el formato y canal más adecuado, en función de los grupos de interés. - Activa el seguimiento y percusión de la crisis en los diferentes medios de comunicación y redes sociales. - Mantiene contacto con los medios de comunicación.
Administración y Finanzas	- Analiza los recursos necesarios para la resolución de la crisis. - Recopila información, evalúa los hechos y plantea opciones. - Mantiene comunicación con las compañías aseguradoras (si aplica).
Infraestructura Física	
Recursos Humanos	- Portavoz ante los funcionarios y en caso de ser aplicable, los representantes. - Gestiona las acciones operativas en caso de incidentes relacionados con personas. - Comunica, llegado el caso, con los afectados y facilita información o asistencia básica (por ejemplo, en caso de una lesión de un funcionario). - Evalúa el ánimo de los funcionarios y recomienda acciones para evitar decaimiento o una evolución no prevista.

Declaración de crisis y equipo responsable según el nivel de criticidad (Impacto y Urgencia):



Ante incidentes con peligrosidad baja y media no deberían requerir la convocatoria de un Comité de Crisis, porque no se encuentra ante una situación que se pueda definir como tal. Bajo la responsabilidad de directa del Encargado de Ciberseguridad y/o quien asigne el Jefe Departamento Tecnologías de la Información y Comunicaciones, los equipos técnicos tienen el conocimiento para solucionar el problema en el nivel operativo.

Atributo	Nivel de criticidad				
	Bajo	Medio	Alto	Muy Alto	Crítico
Declaración de Crisis	NO	NO	OPCIONAL	SI	SI
Nivel	1	2	3	4	5
Ámbito de Gestión / Gobierno de crisis	No requiere comité de crisis	No requiere Comité de Crisis	Requiere Comité de Crisis	Requiere Comité de Crisis	Requiere Comité de Crisis Estratégico
	Responde equipo Operativo	Responde Encargado Área TIC y Negocio	Preside el Ciber/Encargado de Seguridad y/o quien asigne Jefe Departamento Tecnologías de la Información y Comunicaciones	Preside el Ciber/Encargado de Seguridad y/o quien asigne Jefe Departamento Tecnologías de la Información y Comunicaciones	Preside Representante Dirección

En función del **nivel del incidente** actuarán distintos niveles o actores del Comité de crisis:

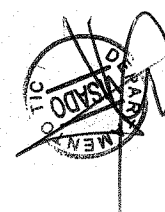
PELIGROSIDAD	TIPO DE COMITÉ	EQUIPO	INTEGRANTES
Baja y Media	Comité de crisis nivel 0 -1	Nivel Operativo	No se requiere del Ciber/Encargado de Seguridad, ni del CEO/DG/P (para estos casos será presidido por el encargado del área TI y responsable de los activos afectados).
Alta y Muy Alta	Comité de crisis nivel 2 – 3	Comité de Crisis	Comité de Crisis sin el CEO/DG/P (para estos casos el comité será presidido por el Ciber/Encargado de Seguridad y/o quien asigne Jefe Departamento Tecnologías de la Información y Comunicaciones).
Crítica	Comité de crisis nivel 4	Comité de Crisis Estratégico	Comité de crisis completo.

6.4 PREPARACIÓN

A continuación, se establecen las herramientas y recursos que deben estar disponibles antes de la gestión de cualquier incidente, deben ser mantenidas y actualizadas por el representante que preside el Comité, de acuerdo con el nivel de Criticidad establecido en punto anterior:

6.4.1 Instalaciones y comunicación para la gestión de incidentes

- **Información de contacto:** Registro de partes interesadas dentro y fuera de la organización (titular y subrogante), tales como Equipo de Respuesta ante Incidentes, Autoridades, Comunicaciones, Jurídica, Recursos Humanos y Administración y Servicios. Los datos de contacto deben incluir a lo menos los números de teléfono y correos electrónicos.
- **Mecanismos de reporte de incidentes:** Todos los funcionarios, el personal a honorarios y terceras partes deben informar, tan pronto como sea posible, debilidades, eventos y/o



incidentes que pueda tener un impacto en la seguridad de los activos de la organización. Al respecto, Minsal dispone los siguientes canales de comunicación únicos de contacto:



- A través del contacto telefónico

+(562) 800 123 573



- Mediante los siguientes correos

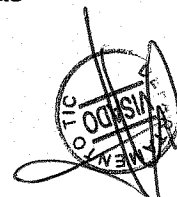
- Para temas técnicos (requerimientos, Incidencias) mds@minsal.cl

- En temas de seguridad (Eventos, debilidades de seguridad, Incidentes, amenazas, riesgos) seguridadtic@minsal.cl

- **Sistema de registro de incidentes:** debe existir un sistema de gestión de incidentes para el monitoreo y seguimiento del estado de los incidentes.
- **Teléfonos móviles:** para ser utilizados por el personal que sea asignado a la gestión de incidentes en terreno o fuera de las dependencias principales.
- **Software de encriptación de comunicaciones:** para las comunicaciones sensibles entre los miembros del equipo de respuesta a incidentes, partes internas y externas, PDI, Ministerio del Interior, etc.
- **Sala de Crisis:** sala (fija o temporal) para la centralización de las comunicaciones y coordinación.
- **Lugar de almacenamiento seguro:** para el almacenamiento de la evidencia u otro material sensible.

6.4.2 Hardware y software para la gestión de incidentes

- **Estaciones de trabajo para actividades forenses y dispositivos de respaldo:** para crear imágenes, conservar logs y guardas otros datos relevantes.
- **Notebooks:** para actividades de análisis de datos, analizar paquetes y escribir reportes.
- **Extra de estaciones de trabajo, servidores, equipamiento de red (físico o virtualizado):** para ser utilizado con diversos propósitos tales como restaurar respaldo o gestionar Malware.
- **Medios extraíbles (pendrive, discos duros, etc.) en blanco.**
- **Impresora.**
- **Analizadores de tráfico:** para capturar y analizar el tráfico de red.
- **Software de análisis forense:** para analizar imágenes de disco.
- **Medios extraíbles con software confiable:** con versiones confiables de programas para la obtención de evidencia desde los sistemas.



- **Accesorios para recopilar evidencias:** tales como notebooks, cámaras digitales, grabadoras de audio, formularios de cadena de custodia, etiquetas y bolsas de custodia, cinta adhesiva de custodia, para las posibles acciones legales.

6.4.3 Recursos para el análisis

- **Listado de puertos:** incluidos los usados comúnmente por trojanos.
- **Documentación:** sistemas operativos, aplicaciones, protocolos y manuales de antivirus.
- **Diagrama de red y listado de activos críticos:** tales como aplicaciones, bases de datos, servidores, etc.
- **Línea base:** de la red, sistema y actividades de las aplicaciones.
- **Arquitectura del Sistema afectado.**

6.4.4 Software para mitigación

- **Acceso a imágenes:** de sistemas operativos y aplicaciones para recuperación y restauración.

6.5 IDENTIFICACIÓN

Si se determina que corresponde a un incidente que requiere la actuación de uno de los Comité de Crisis, se debe dar aviso de inmediato a sus miembros, y el Encargo del Comité según el nivel que corresponda debe coordinar las acciones de contención y erradicación.

A partir de este momento se debe mantener registro de todas las actividades y comunicaciones realizadas, estos registros deben permitir dar respuesta a las siguientes preguntas: ¿quién?, ¿qué?, ¿dónde?, ¿por qué? y ¿cómo?

En esta etapa se activan las actividades de comunicación al interior de la organización y con terceras partes, dependiendo del tipo y nivel del incidente.

Una vez determinado el alcance del incidente, la activación del comité de crisis y el registro de lo ocurrido se debe avanzar a la siguiente fase.

Nota 1: en cualquiera de las fases si el comité de crisis determina que el alcance del incidente es mayor a lo definido inicialmente, el presidente del comité debe escalar al Comité Superior de gestión de incidencias.

6.6 CONTENCIÓN

El Comité de Crisis en conjunto dirigidos por el presidente respectivo, coordinan la contención del incidente, tratando de minimizar los daños, dependiendo del tipo de

incidencia, serán distintos los responsables de las acciones de contención (ver punto 6.1 de este procedimiento).

Los pasos para la contención son:

- a) **Acciones inmediatas de contención:** destinadas a detener de inmediato el incidente y contener los daños. Un ejemplo de estas acciones es la aislación de un segmento de red con estaciones infectadas, sacar de producción servidores que se encuentren comprometidos, apagar switch, etc.

Las acciones inmediatas de contención no pretenden ser soluciones a largo plazo o soluciones definitivas, solamente limita el incidente a que sea peor.

- b) **Respaldo de la información:** se deben realizar respaldos de los activos afectados, para preservar la evidencia, para el posterior análisis forense y las acciones legales pertinentes.

- c) **Acciones de contención para restablecer las operaciones:** en este paso se deben implementar las acciones de remediación para restablecer las operaciones, por ejemplo: levantar respaldos, activar sites de contingencia, activar procesos manuales, etc.

En esta etapa básicamente se remueven las cuentas comprometidas, puertas traseras instaladas por los atacantes, instalación de parches de seguridad, y cualquier acción destinada a evitar que el incidente escale.

6.7 PLAN DE COMUNICACIÓN

Para la notificación de los incidentes de seguridad se utilizará como criterio de referencia el Nivel de peligrosidad que se asigne a un incidente, sin perjuicio de que, a lo largo del desarrollo, mitigación o resolución de este, se categorice con un determinado Nivel de impacto que requiera de un Plan de Comunicaciones del incidente a los actores involucrados, que considera las comunicaciones, tanto entre equipos de trabajo (árbol de llamadas) como con clientes, proveedores.

Los que deberán ser informados al Encargado de Seguridad de la Información y Ciberseguridad, quien a su vez informará a los al Jefe del Departamento de Tecnologías, los incidentes cuyo nivel de severidad sea Rojo. El plan de comunicación podrá considerar las siguientes instancias de comunicación:

- Encargado de Seguridad de la Información y Ciberseguridad
- Jefe del Departamento de Tecnologías
- Jefe Gabinete Ministro
- Jefe Gabinete SRA
- Jefe Gabinete SSP
- Director Operativo CSIRT
- Director General CSIRT
- Consejo Nacional de Ciberseguridad (CNC)
- Subsecretario del Interior

- Ministro de Interior y Seguridad Pública
- Presidente de la República

Es importante que de acuerdo con el nivel de severidad del incidente este sea comunicado en forma preventiva al Coordinador SOC, quien a su vez será la persona que informe en detalle del incidente a el director Operativo y General de CSIRT.

De ser requerida una comunicación oficial hacia medios públicos esta deberá ser coordinada con el Jefe del Departamento de Comunicaciones quien visará el texto a publicar y los medios que serán utilizados.

6.8 ERRADICACIÓN

En esta etapa el Comité de Crisis gestiona la restauración de los activos afectados, se deben ejecutar todas las acciones necesarias para remover cualquier contenido malicioso o ilícito, asegurando que los sistemas o procesos se encuentran "limpios". En esta etapa se deben implementar todas las protecciones necesarias para evitar que el incidente nuevamente ocurra, en base de lo aprendido durante las etapas anteriores (por ejemplo: instalación de parches, actualización de sistemas, compra de equipamiento, etc.).

6.9 RECUPERACIÓN

El comité de crisis gestiona la recuperación de los procesos, una vez las vulnerabilidades han sido erradicadas, asegurando que el incidente no se repetirá. Se debe mantener el testeo, monitoreo y validar que la solución ha sido efectiva.

Durante esta etapa se debe definir:

- Fecha y hora de la restauración de las operaciones.
- Metodología de testeo para verificar que los activos afectados no son vulnerables y son completamente funcionales.
- La duración del monitoreo de los activos para verificar cualquier comportamiento anómalo.
- Las herramientas para el monitoreo y validación del comportamiento de los activos afectados.

6.10 LECCIONES APRENDIDAS

En esta etapa el presidente del Comité de Crisis según corresponda, debe gestionar que todas las actividades realizadas en la gestión de la incidencia estén correctamente documentadas, junto con registrar cualquier otra información que sea de beneficio para futuros incidentes. El informe debe dar cuenta de quién, qué, dónde, por qué y cómo de la incidencia.

El informe no debe tardar más de dos semanas en su confección y aprobación.

Los campos mínimos del informe deberían contener:



- Cuando fue detectado el problema y por quién.
- El alcance de la incidencia.
- Cómo fue contenido y erradicado.
- Trabajos realizados durante la recuperación.
- Áreas en donde el Comité fue efectivo.
- Áreas en los que se necesita mejorar.
- Recomendaciones de mejora para la gestión de incidencias.

7 REGISTROS

- Informe de gestión de la incidencia.
- Evidencia recopilada durante el proceso.
- Registros de las actividades ejecutadas durante la gestión de la incidencia.

8 DIFUSION

La comunicación del presente procedimiento se efectuará de manera que el contenido de la documentación sea accesible y comprensible para todos los usuarios, a lo menos se deberá hacer difusión mediante los siguientes canales:

- Publicación en la intranet de Minsal <http://isalud.minsal.cl/>
- Correo informativo.

9 REVISION Y MEDICION

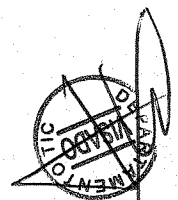
El presente procedimiento deberá ser revisado a lo menos cada dos años o cuando ocurran cambios significativos para asegurar su continua idoneidad, eficiencia y efectividad.

10 EXCEPCIONES AL CUMPLIMIENTO DEL PROCEDIMIENTO

Frente a casos de especiales, el Comité de Seguridad de Información evaluará la situación y podrá establecer condiciones puntuales de excepción en el cumplimiento del presente procedimiento, siempre que no infrinja las políticas internas existentes. Toda excepción debe ser documentada y generar un proceso de revisión del procedimiento, que determine si se deben agregar condiciones de operación particulares.

11 CONTROL DE VERSIONES

Versión	Fecha de Aprobación	Motivo del cambio	Secciones modificadas
1	Diciembre 2020	Creación del documento	N/A



12 ANEXO: CHECKLIST GESTIÓN DE INCIDENCIAS

PREPARACIÓN

- Todos los miembros del Comité son conscientes de las políticas de Seguridad
- Todos los miembros del Comité tienen claro a quién contactar en caso de incidentes.
- Todos los miembros del comité tienen acceso a herramientas, equipamiento y registros para la ejecución del proceso de gestión de incidentes.
- Todos los miembros tienen experiencia o han realizado simulacros de incidentes.

IDENTIFICACIÓN

- Dónde ocurrió el incidente.
- Quién reportó o descubrió el incidente.
- Cómo fue descubierto.
- Hay más de un área comprometida en el incidente, si es así cuáles y cuando fue descubierto.
- Cuál es el impacto del incidente.
- Las fuentes del incidente se encuentran identificadas (dónde, cuándo y cuáles son)

CONTENCIÓN

Acciones inmediatas de contención:

- ¿El problema puede ser aislado?
 - Si es así, asilar el problema.
 - Si no, gestionar con los dueños y encargados de los activos, y terceras partes relevantes, para determinar las acciones necesarias para contener el problema
- ¿Todos los activos comprometidos están aislados de los activos no comprometidos?
 - Si es así, continuar al siguiente paso.
 - Si no, continuar con el proceso para aislar el problema, para evitar escalamiento a otros activos.

Respaldo de la información:

- ¿Las copias forenses de los activos afectados han sido creados y resguardados para futuros análisis?
- ¿Todos los comandos y otra documentación relevante, desde que ocurrió el incidente se mantiene actualizada?



- Si no es así, documentar todas las acciones tomadas lo más pronto posible, para asegurar que toda la evidencia se retenga para análisis futuros (técnicos y regales) y/o lecciones aprendidas.
- ¿Las copias forenses se encuentran almacenadas en lugares seguros?
 - Si es así continuar al siguiente paso.
 - Si no, resguardarlas en un lugar seguro, para prevenir pérdida o manipulación indebida.

Acciones de contención para restablecer las operaciones:

- Si el activo puede ser aislado del proceso y continuar con las operaciones, proceder a la fase de erradicación.
- Si el activo debe continuar en el proceso, proceder con las acciones para restablecer las operaciones, removiendo cualquier vulnerabilidad que afecte al activo (remover malware, hardening, etc.).

ERRADICACIÓN

- ¿Los activos afectados pueden ser rediseñados o fortalecidos (hardening), mediante parches, u otras contramedidas para reducir el riesgo de ataques?
 - Si no, responder ¿por qué?
- ¿Todas las vulnerabilidades y otros artefactos utilizados por el atacante han sido removidos, y los activos fortalecidos contra esas vulnerabilidades?
 - Si no, responder ¿por qué?

RECUPERACIÓN

- ¿Todos los activos afectados han sido parchados fortalecidos frente al ataque reciente, existen posibilidades de un ataque futuro?
- Fecha y hora en que los procesos pueden ser restablecidos.
- ¿Qué herramientas se utilizarán para testar, monitorear y verificar que los procesos han sido restablecidos y no son vulnerables a los mismos métodos de ataque del incidente original?
- ¿Durante cuanto tiempo se monitoreará los procesos restablecidos?
- ¿Existen indicadores que permitan definir una línea base, para medir el grado de cumplimiento de los procesos restaurados?

LECCIONES APRENDIDAS

- ¿Existe toda la documentación del incidente?
 - Si es así, generar el Informe de Incidente.
 - Si no, generar la documentación lo más pronto posible, antes que la información sea olvidada o perdida.

- Asumiendo que el informe de gestión de incidentes existe, ¿responde a las siguientes preguntas: ¿qué?, ¿dónde?, ¿por qué? y ¿cómo?
- ¿Es posible generar el informe de incidentes dentro de las dos semanas posteriores al incidente?
 - Explicar por qué, y cuando estará disponible el informe.
- En la reunión de lecciones aprendidas:
 - Analizar el proceso de respuesta al incidente con todos los miembros del comité.
 - ¿Existen áreas en las que sea necesario mejorar?
 - Si no existen, explicar por qué.

13 ANEXO: Orientaciones sobre niveles y criterio de evaluación y clasificación de crisis

Tipología de Impacto	Atributo	Nivel de criticidad				
		Bajo	Medio	Alto	Muy Alto	Crítico
Externo	Afectación a la seguridad nacional	--	--	--	Afecta apreciablemente a actividades oficiales o misiones en el extranjero	Afecta apreciablemente a la seguridad nacional
Externo	Afectación a la seguridad ciudadana	--	--	--	Afecta a la seguridad ciudadana con potencial peligro para bienes materiales	Afecta a la seguridad ciudadana, con potencial peligro para la vida de las personas
Interno	Afectación a infraestructuras críticas/servicio esencial	--	--	--	Afecta a un servicio esencial	Afecta a una infraestructura crítica
Interno	Afectación a sistemas	Afecta a los sistemas de la organización	Afecta a más del 20 % de los sistemas de la organización	Afecta a más del 50 % de los sistemas de la organización	Afecta a sistemas clasificados RESERVADO Afecta a más del 75 % de los sistemas de la organización	Afecta a sistemas clasificados SECRETO Afecta a más del 90 % de los sistemas de la organización
Interno	Interrupción del servicio	Interrupción de la prestación de un servicio	Interrupción en la prestación del servicio superior al 5 % de usuarios	Interrupción en la prestación del servicio superior a 1 hora y superior al 10 % de usuarios	Interrupción en la prestación del servicio superior a 8 horas y superior al 35 % de los usuarios	Interrupción en la prestación del servicio superior a 8 horas y superior al 50 % de los usuarios
Interno	Recursos en jornadas personas	El incidente precisa para resolverse menos de 1 jornadas-persona	El incidente precisa para resolverse entre 1 y 5 jornadas-persona	El incidente precisa para resolverse entre 5 y 50 jornadas-persona	El incidente precisa para resolverse entre 50 y 100 Jornadas-Persona	El incidente precisa para resolverse más de 100 Jornadas-Persona
Interno	Impacto económico	Entre 0,0001 % y 0,002 % del PIB actual	Entre el 0,001% y 0,05 % del PIB actual	Entre el 0,05 % y el 0,07 % del PIB actual	Entre el 0,07 % y el 0,1 % del PIB actual	Superior al 0,1 % del PIB actual
Externo	Afectación geográfica	Superior a 1 Reg.	Superior a 2 Reg.	Superior a 3 Reg.	Superior a 4 Reg.	Extensión geográfica supranacional
Externo	Impacto reputacional	Puntual, sin eco mediático	Daños reputacionales apreciables, con eco mediático (amplia cobertura en los medios de comunicación)	Daños reputacionales de difícil reparación, con eco mediático (amplia cobertura en los medios de comunicación) y afectando a la reputación de terceros	Daños reputacionales a la imagen del país (marca España) y cobertura continua en medios de comunicación nacionales	Daños reputacionales muy elevados y cobertura continua en medios de comunicación internacionales



PROCEDIMIENTO GESTIÓN DE CRISIS POR INCIDENTES DE SEGURIDAD - PROS-NC-012

MINISTERIO DE SALUD

Versión: 01

Página 19 de 19

Interno / actividad / operaciones	Afectación a los procesos críticos	Sin afectación en procesos críticos	Con afectación a procesos críticos y recuperación de la actividad interrumpida dentro de su RTO ²	Recuperación de una actividad interrumpida ligeramente por encima de su RTO (%)	Recuperación de una actividad interrumpida por encima de su RTO (%)	Recuperación de una actividad interrumpida o desconocida o muy por encima de su RTO (%)
Social	Afectación a las relaciones con los grupos de interés	Las expectativas y la confianza de los grupos de interés no se ven afectadas	Las expectativas y la confianza de los grupos de interés no se ven afectadas	Las expectativas y la confianza de los grupos de interés se verán mínimamente afectadas	Las expectativas y la confianza de los grupos de interés se verán afectadas de manera considerable	Las expectativas y la confianza de los grupos de interés y la relación con estos se verán fuertemente afectadas durante un largo periodo de tiempo
Social	Alarma social	Sin alarma	Sin alarma	Principio de alarma en población con/sin causa justificada	Alarma en población con/sin causa justificada	Pánico en población con/sin causa justificada
Económico	Daños a terceros / entorno	Sin daños a terceros / entorno	Daños materiales leves	Daños moderados	Daños graves	Daños muy graves
Económico	Pérdidas económicas (estimación)	Sin pérdidas o pérdidas insignificantes. Coste dentro de parámetros presupuestarios aceptables	Pérdidas por valor hasta coste de reposición	Pérdidas por valor hasta coste de reposición	Pérdidas por valor hasta coste de reposición	Pérdidas por valor hasta coste de reposición
Legal	Implicaciones legales	Sin implicaciones	Sin implicaciones	Sin implicaciones	Reclamaciones aisladas de terceros y/o indicios de delito	Pérdidas por valor hasta coste de reposición
De gestión	Declaración de crisis	No	No	Opcional	Sí, de nivel MUY ALTO	Sí, de nivel CRÍTICO

² RTO Tiempo objetivo de recuperación

